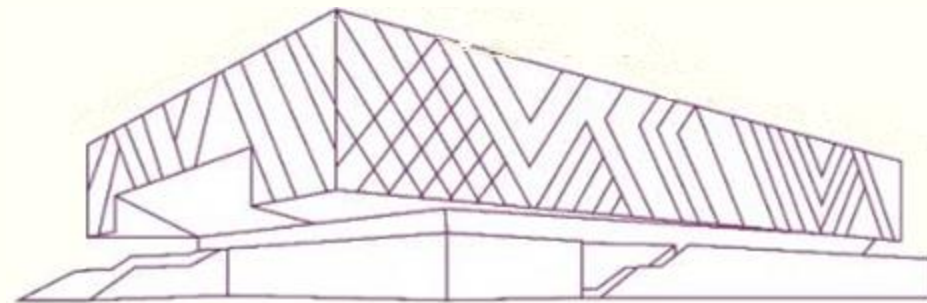




天津工业大学
TIANJIN POLYTECHNIC UNIVERSITY

第四章 攻击与防范

—— 入侵防御与Internet安全协议 ——





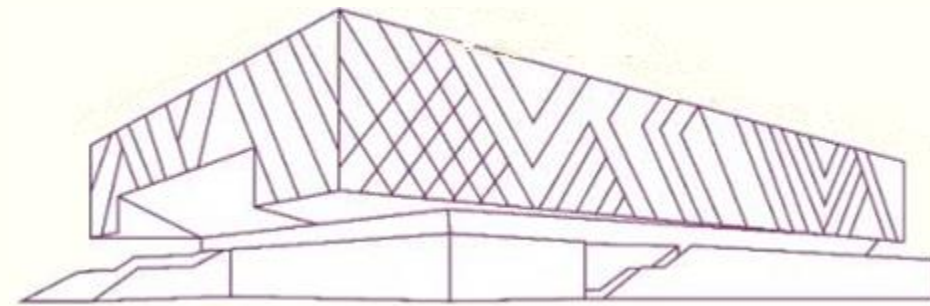
问题与思考

1. 网络攻击造成的危害?
2. 网络安全面临的挑战是什么?
3. 本课程所解决的网络攻击是什么?



一、网络攻击简介

二、常见网络攻击与防护



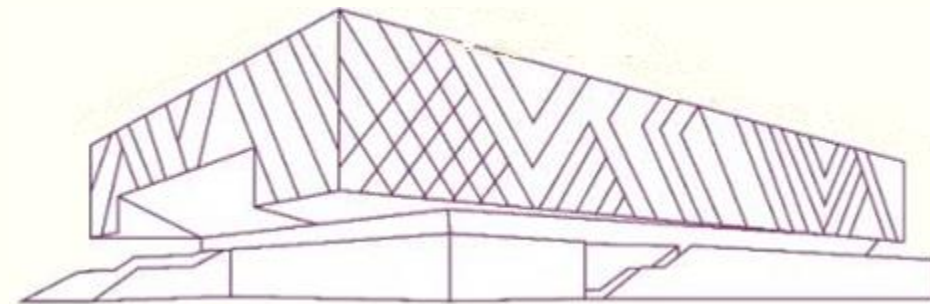


一、网络攻击简介

攻击从实验室走向了Internet

攻击手段持续升级

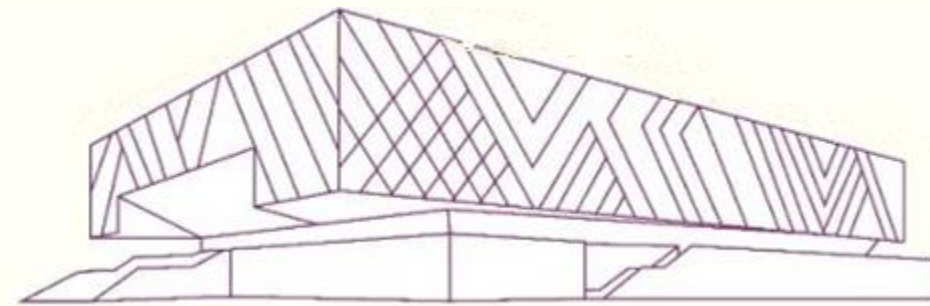
防御技术不断提高





1、什么是网络攻击

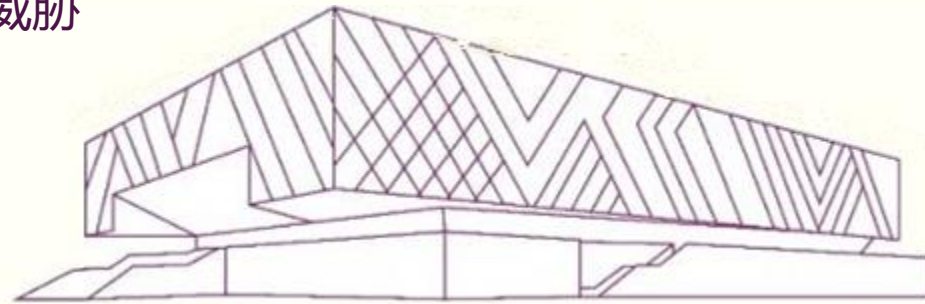
- 攻击对象：
 - 计算机信息系统、基础设施
 - 计算机网络、个人计算机设备
- 进攻动作：
 - 破坏、揭露、修改、使软件或服务失去功能
 - 未授权的访问任何一计算机的数据。





2、大数据时代，网络空间的特点

- 大数据时代
 - 所行所思、消费习惯、行程安排、关系网络，数字巨头比你更了解你自己，获取便利的同时也签署条约共享个人信息。
 - 光缆的尽头是宝藏，数据引来贪婪的窥探者。
 - 一组代码，可能导致个人倾家荡产，国家基础设施瘫痪，风险隐于键盘之上。
- 网络空间成为继陆地、海洋、天空、外空之外的第五空间。
 - 虚拟空间和现实世界深度融合
 - 不断涌现的各种已知和未知的网络安全威胁
 - 网络空间安全维护面临极大挑战



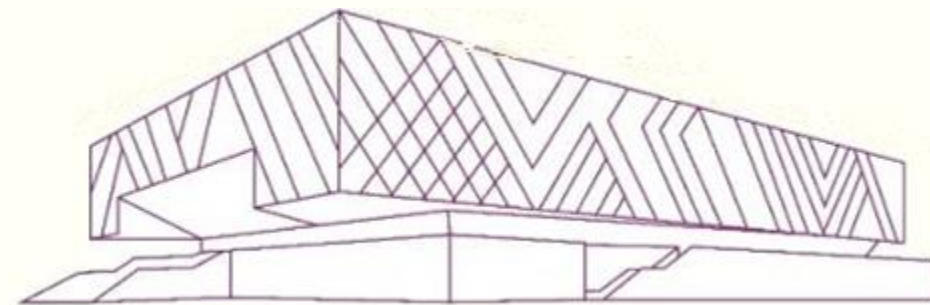
进入透明时代，网络已成为继时间空间





2、网络攻击造成的严重后果

- 进入透明时代，个人信息随时泄露，造成家破人亡的惨剧



大规模网络攻击之红色幽灵

2017年5月12日 周五

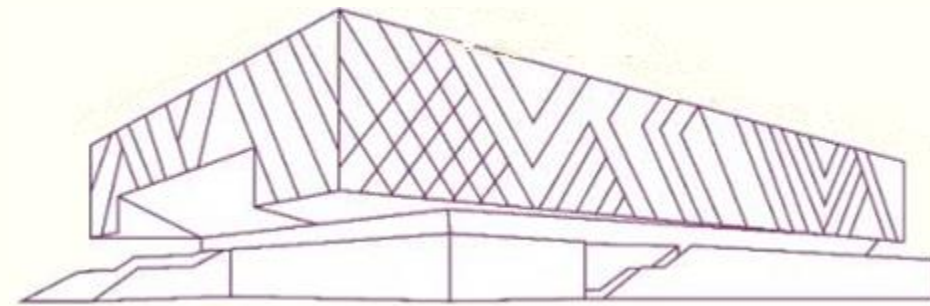
2017年5月12日

第5空间
CYBER SPACE



2、网络攻击造成的严重后果

- 进入透明时代，个人信息随时泄露，造成家破人亡的惨剧
- 利用系统漏洞，依法红色幽灵病毒，勒索用户，公共服务瘫痪，行业正常运行遭破坏，引发社会恐慌



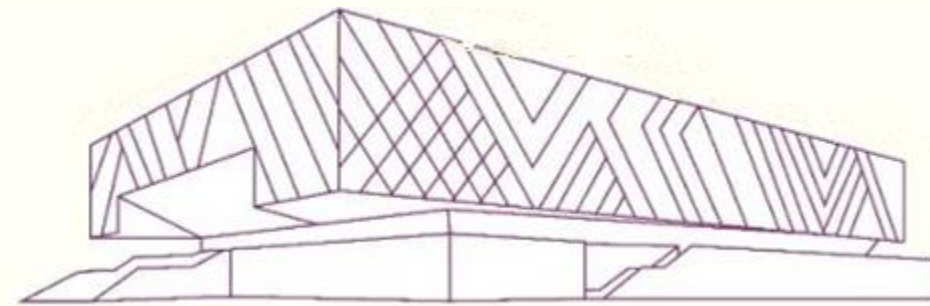
没有网络安全就没有国家安全





2、网络攻击造成的严重后果

- 进入透明时代，个人信息随时泄露，造成家破人亡的惨剧
- 利用系统漏洞，依法红色幽灵病毒，勒索用户，公共服务瘫痪，行业正常运行遭破坏，引发社会恐慌
- 国家基础设施遭到破坏，国家主权完整遭到威胁



共同构建网络空间命运共同体



-

网络安全 人人有责



3、攻击分类

主动型攻击

导致某些数据流的篡改

- ◆ 篡改
- ◆ 伪造
- ◆ 终端拒绝服务
- ◆ 产生虚假数据流

被动型攻击

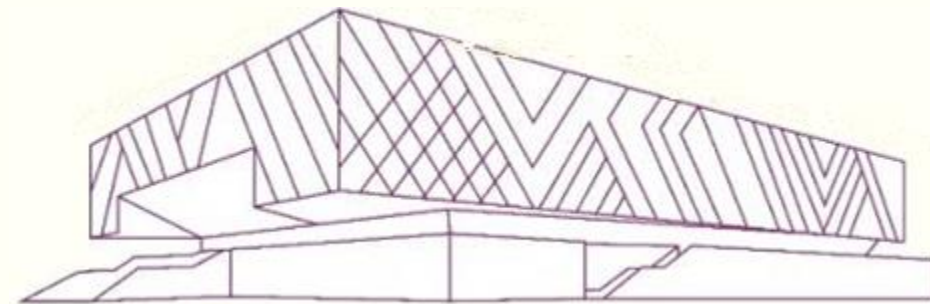
不对数据信息做任何修改

- ◆ 窃听
- ◆ 流量分析
- ◆ 破解弱口令加密



二、常见网络攻击简介

D O S 攻 击
流 量 攻 击
畸 形 报 文 攻 击
特 殊 报 文 攻 击

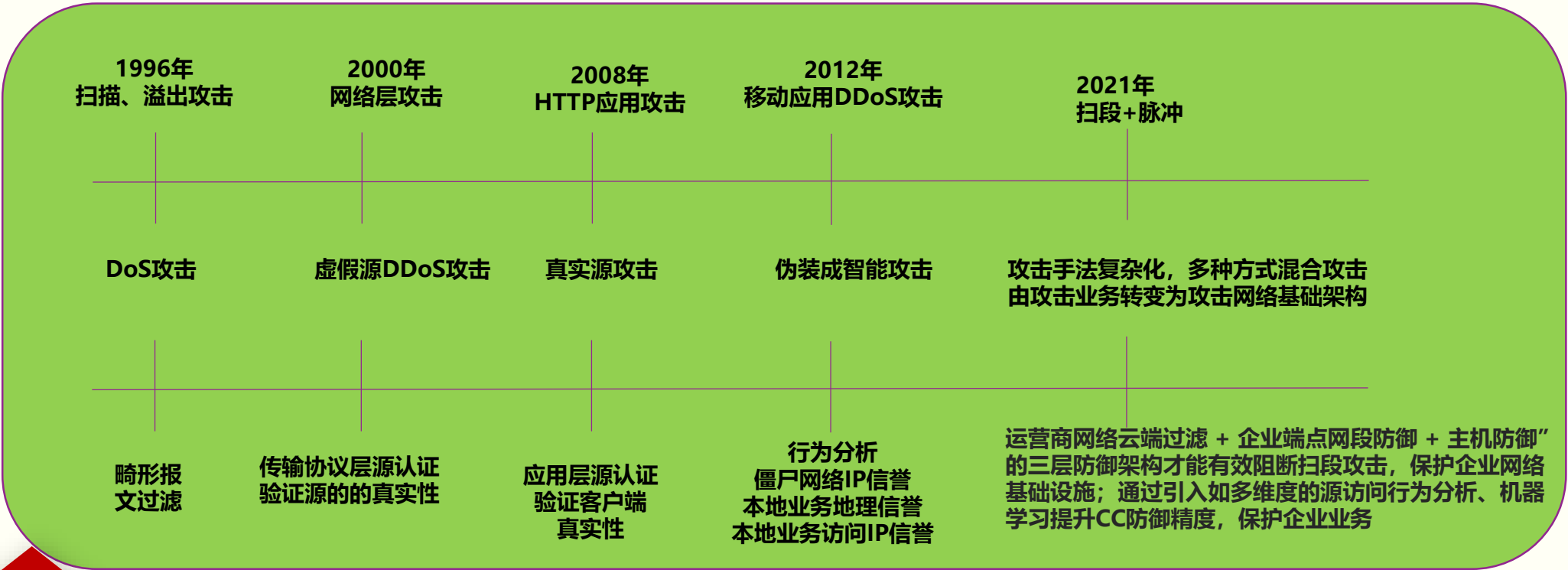


DOS攻击

- 定义
 - Denial of Service的简称，即拒绝服务
 - 使计算机或网络无法提供正常服务的攻击。
 - 最常见的DoS攻击有计算机网络宽带攻击和连通性攻击。
- 特点：
 - 简单粗暴
 - 无法提供正常的服务或资源访问，
 - 使目标系统服务系统停止响应甚至崩溃，
 - 无法避免这种攻击带来的后果。

网络攻击界的“板砖”：DDOS攻击

攻击持续升级
防御技术不断跟进

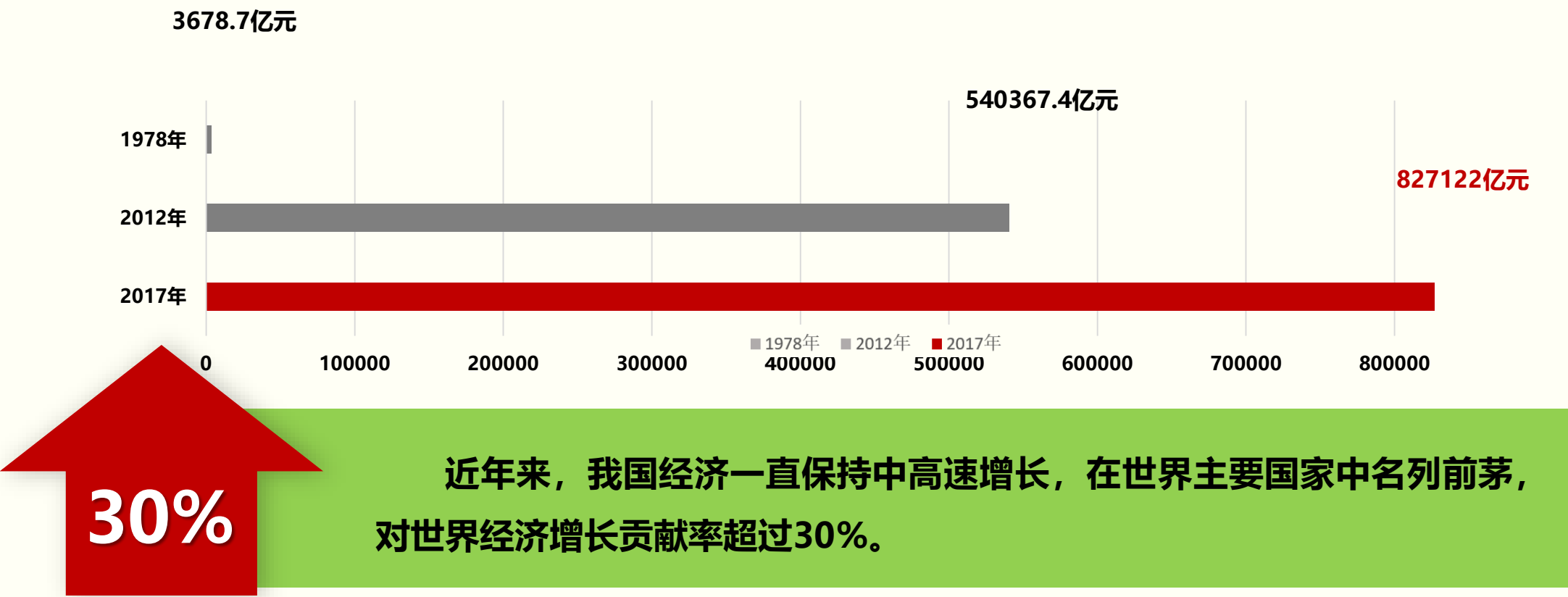


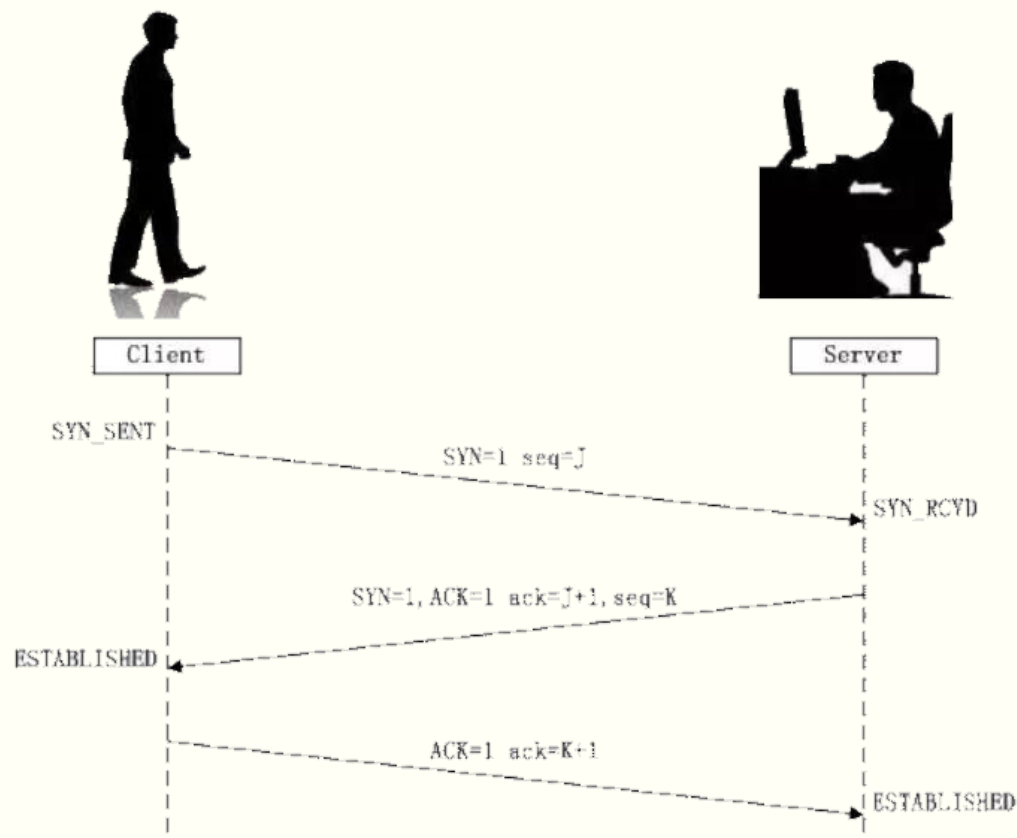
3.5倍

大流量攻击常态化，攻击次数成数倍增长，84.37%的攻击采用混合攻击手法，假冒QUIC的T级攻击将“Fast Flooding”攻击上升速度进一步提升61%。

网络攻击界的“板砖”：DDOS攻击

通过几十年来的发展，我国已经从“未发展起来”时期进入到“发展起来”时期。





第一次握手:建立连接时, 客户端发送SYN包($\text{SYN}=i$)到服务器, 并进入SYN SEND状态, 等待服务器确认;

第二次握手:服务器收到SYN包, 必须确认客户的SYN ($\text{ACK}=i+1$), 同时自己也发送一个SYN包($\text{SYN}=j$)即SYN+ACK包, 此时服务器进入SYN_RECV状态

第三次握手:客户端收到服务器的SYN+ACK包, 向服务器发送确认包ACK($\text{ACK}=j+1$), 此包发送完毕, 客户端和服务器进入ESTABLISHED状态



通过向网络服务所在端口发送正常报文，实现正常服务



通过向网络服务所在端口发送大量的伪造源地址的报文，就可能造成目标服务器中的半开连接队列被占满，从而淹没了合法用户的访问（早期操作系统含有这种漏洞）

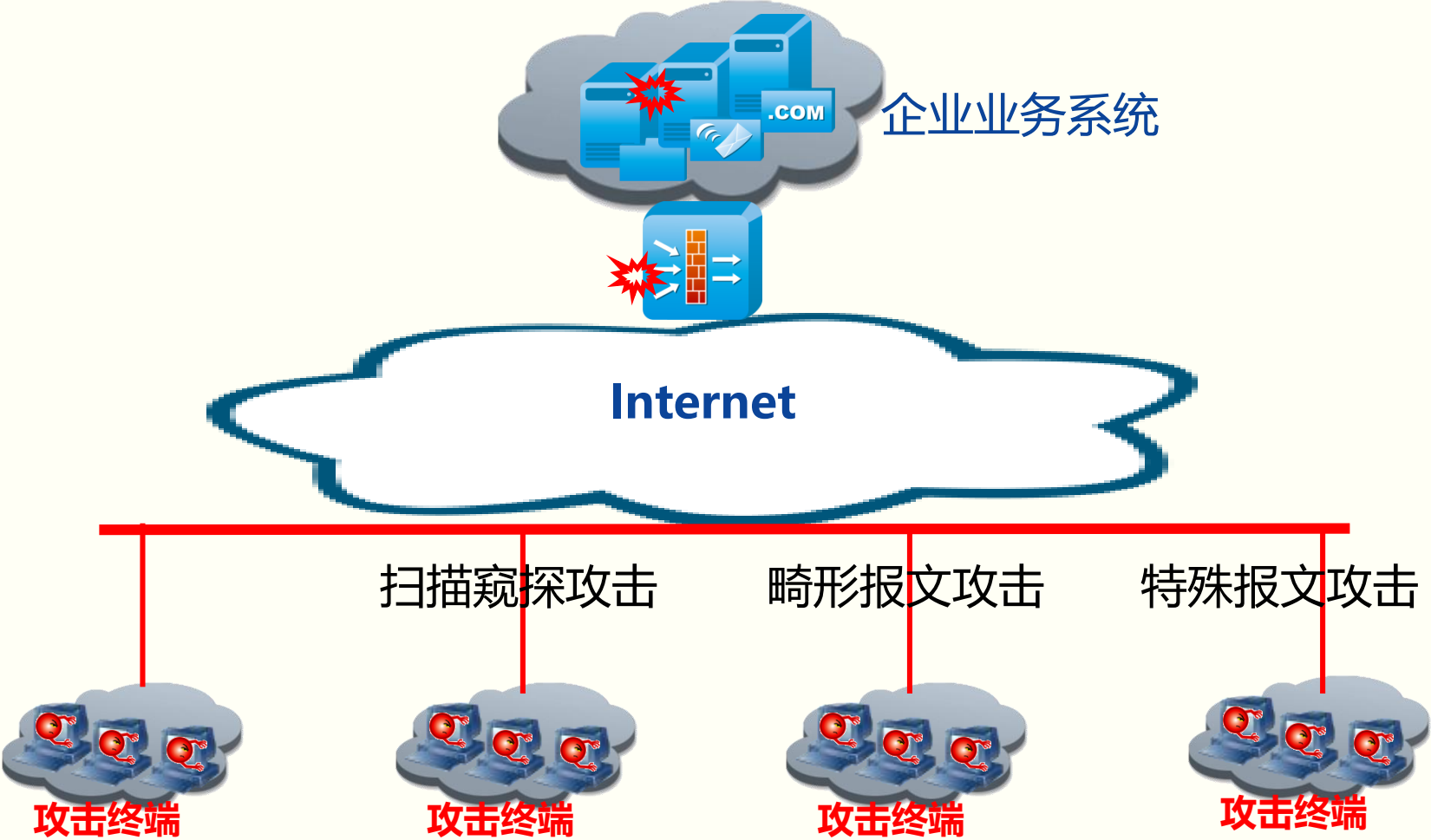


当服务器崩溃之后，正常访问的用户就得不到服务。

防火墙单包攻击



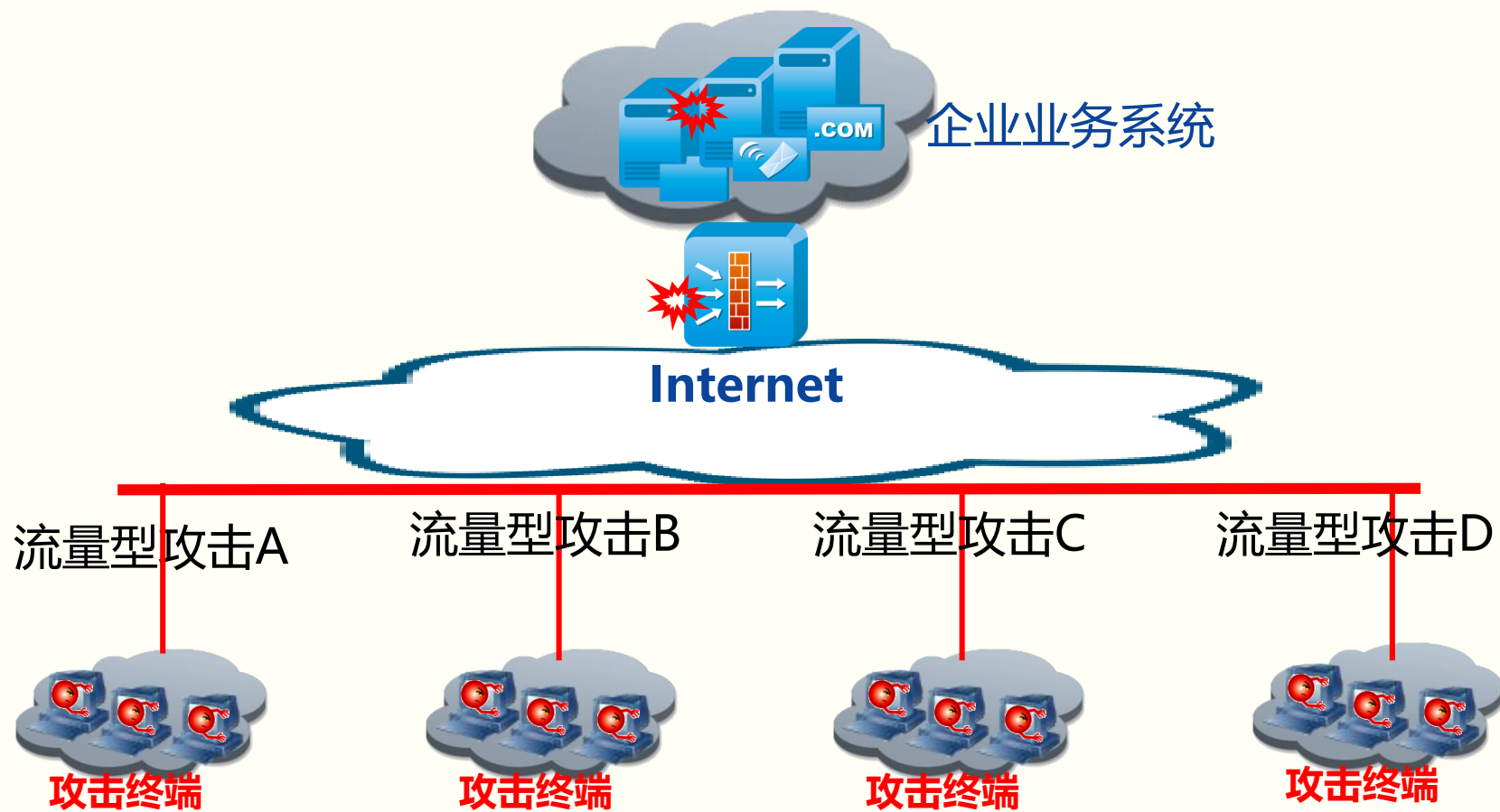
流量型攻击

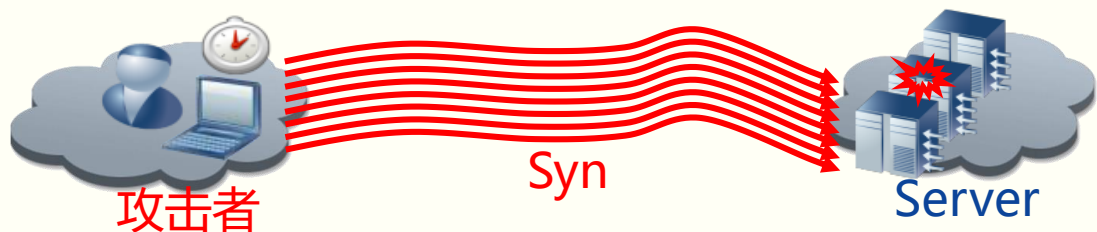


Flood方式攻:

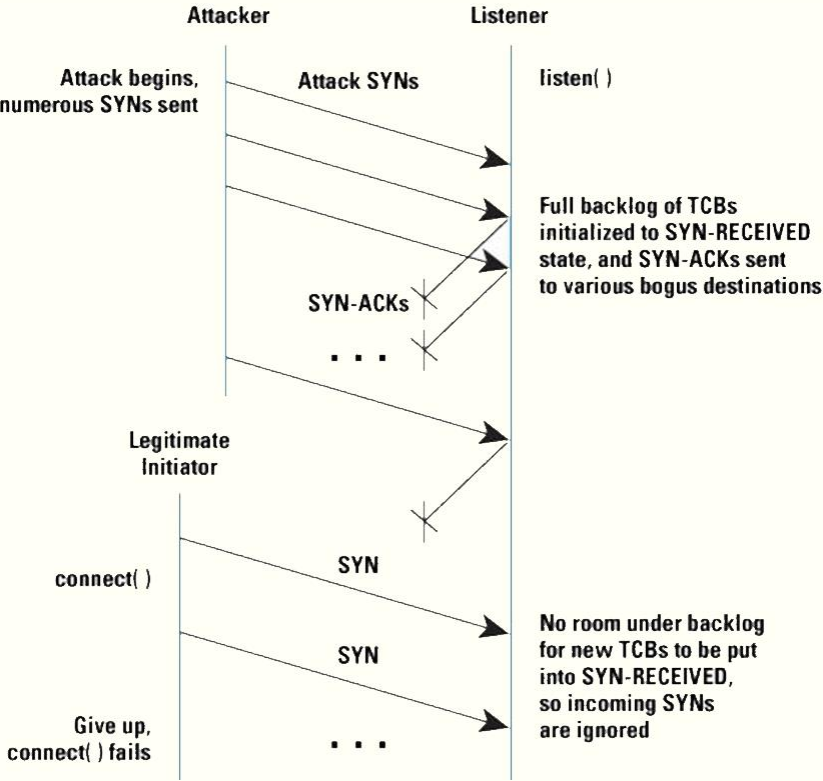
耗尽网络带宽

耗尽服务器资源





SYN Flood攻击防范



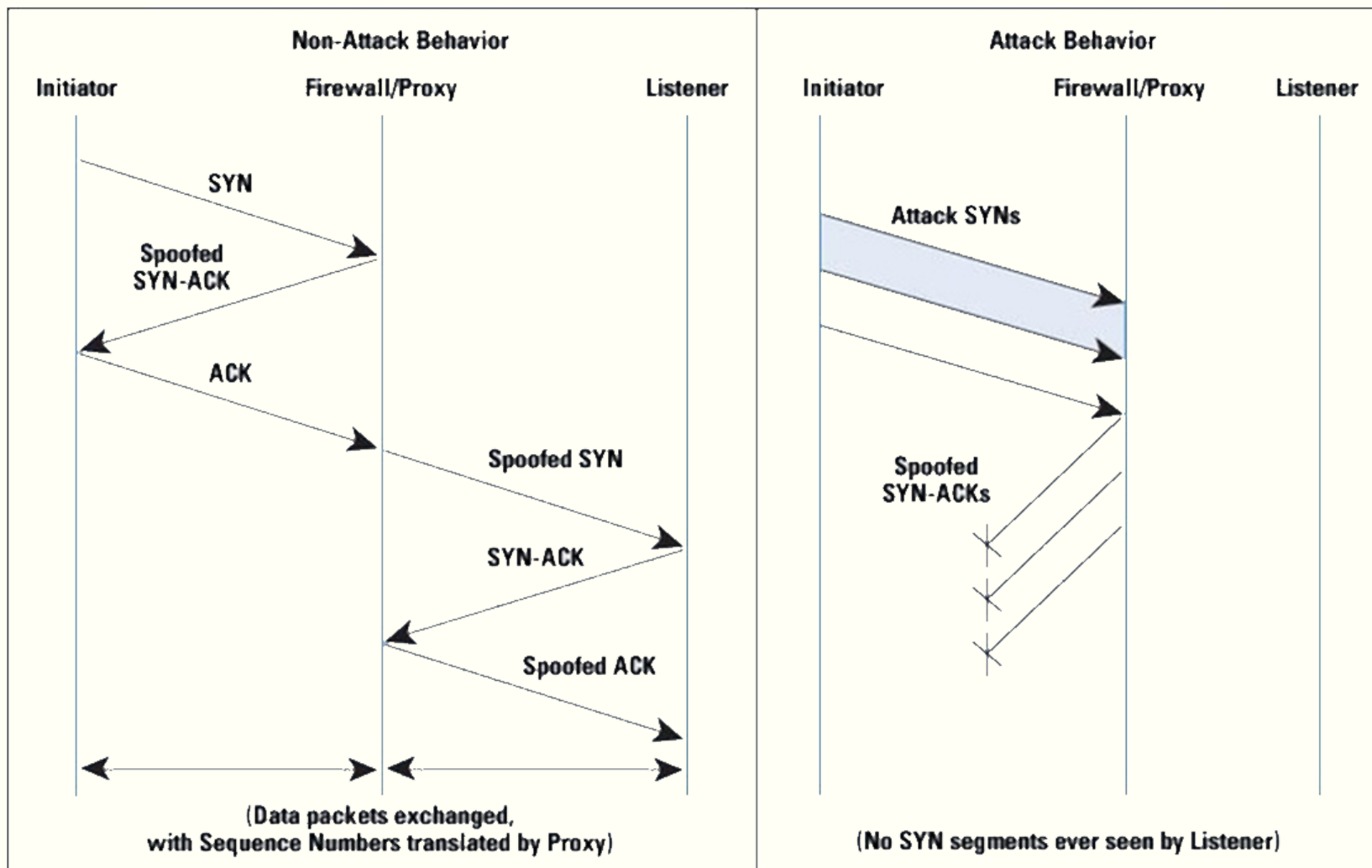
● 攻击介绍

- SYN Flood攻击就是采用源地址伪造的方式对目标主机发送大量的SYN报文，导致目标主机瘫痪。

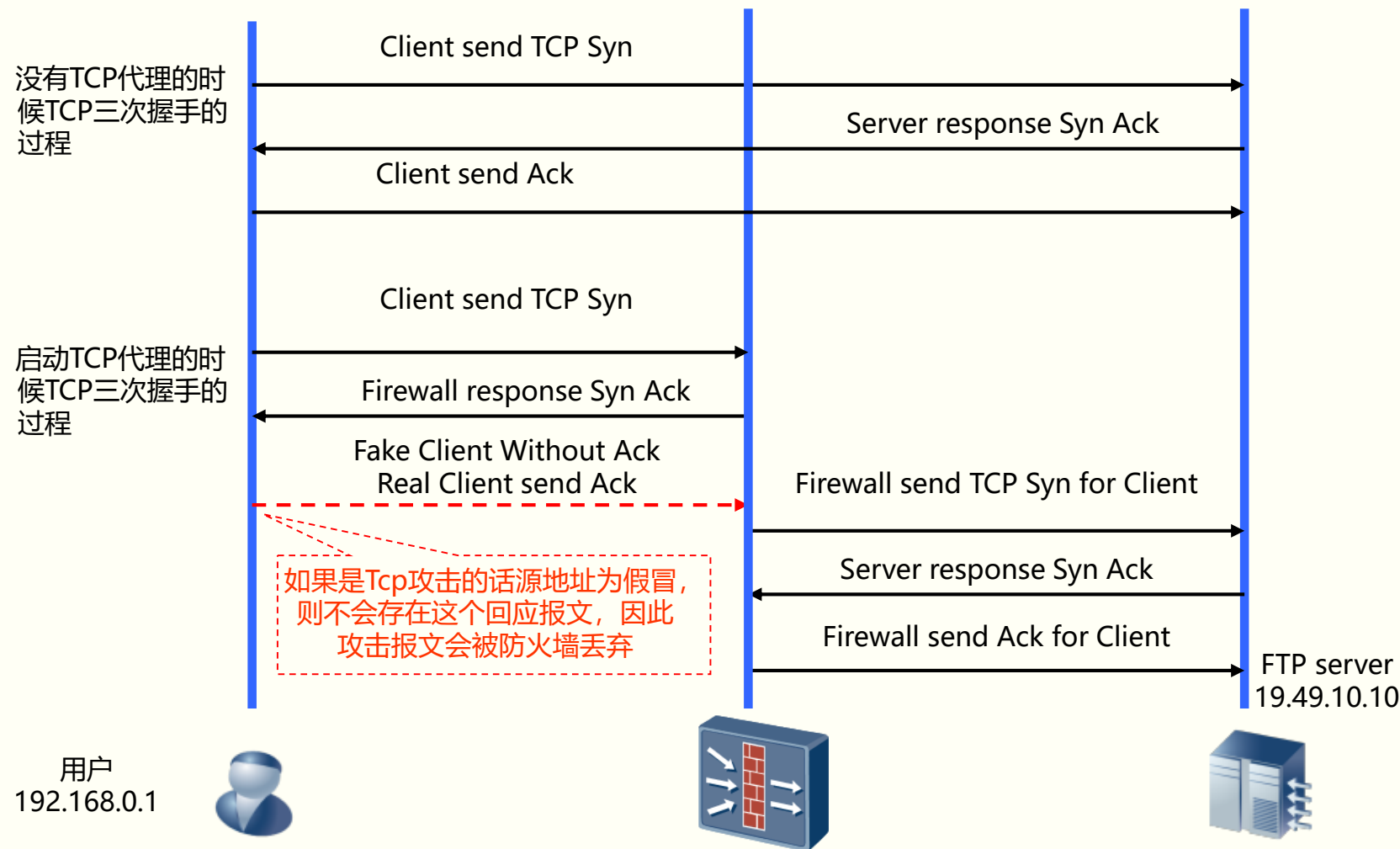
● 处理方法

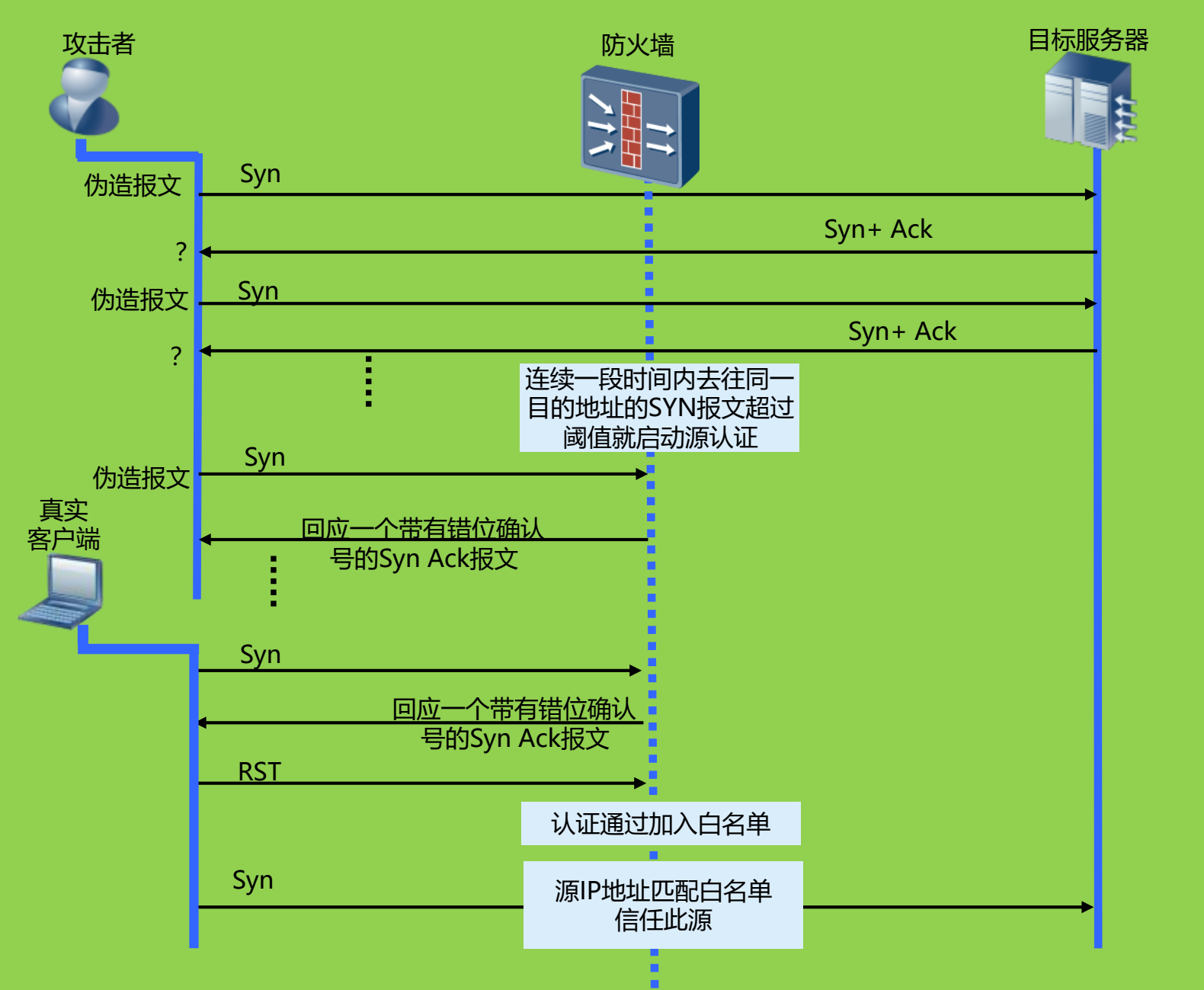
- 采用TCP PROXY的方式进行SYN Flood攻击防御，其基本参数就是需要指定对哪些主机进行保护；
- 反向源探测技术；
- 目标主机进行SYN报文限速的方式进行防御。

SYN FLOOD防范原理—TcpProxy技术



SYN FLOOD防范原理—TcpProxy技术





SYN FLOOD防范原理—Tcp源探测技术

SYN Flood攻击防范配置（一）

● 攻击防范配置

▣ syn flood攻击防范开关

- [USG] firewall defend syn-flood enable

▣ 基于接口进行syn flood增强型攻击防范

- [USG] firewall defend syn-flood interface all [max-rate rate-value][tcp-proxy { auto | off | on }]
- [USG] firewall defend syn-flood interface Ethernet slot-number[max-rate rate-value] [tcp-proxy { auto | off | on }]
- [USG] firewall defend syn-flood interface GigabitEthernet slot-number [max-rate rate-value] [tcp-proxy { auto | off | on }]

SYN Flood攻击防范配置（二）

● 攻击防范配置

▫ 基于安全域进行syn flood攻击防范

- [USG] firewall defend syn-flood zone zone-name [max-rate rate-value] [tcp-proxy { auto | off | on }]

其中：

- **zone-name**：被保护安全区域名称；
- **rate-value**：允许通过TCP报文速率，取值范围为1 ~ 65535，缺省1000，单位为包/秒；
- **auto**：自动启用TCP-PROXY防范功能，tcp-proxy缺省配置；
- **off**：不启用TCP-PROXY防范功能；
- **on**：直接启用TCP-PROXY防范功能。

SYN Flood攻击防范配置（三）

● 攻击防范配置

▫ 基于IP地址进行syn flood攻击防范

- [USG] firewall defend syn-flood ip ip-addr [max-rate rate-value] [tcp-proxy { auto | off | on }]

其中：

- **ip-addr**：被保护IP地址；
- **rate-value**：允许通过TCP报文速率，取值范围为1 ~ 65535，缺省是1000，单位为包/秒；
- **auto**：自动启用TCP-PROXY防范功能，tcp-proxy缺省配置；
- **off**：不启用TCP-PROXY防范功能；
- **on**：直接启用TCP-PROXY防范功能。

UDP Flood攻击防范

- **攻击介绍**

- 短时间内向特定目标发送大量的UDP/ICMP报文，致使目标系统负担过重而不能处理合法的连接。

- **处理方法**

- 检测通向特定目的地址的UDP报文速率，当速度超过设定阈值上限时，设定攻击标志并做处理，对攻击记录日志。当速率低于设定的阈值下限，取消攻击标志，允许所有报文通向特定目的地址。

UDP Flood攻击防范-限流

- **基于流量入口的限流**

- 以某个入接口流量作为统计对象，对通过该接口的UDP流量进行统计并限流，超出流量将被丢弃。

- **基于目的IP地址的限流**

- 以某个IP地址作为统计对象，对到达该IP地址的UDP流量进行统计并限流，超出流量将被丢弃。

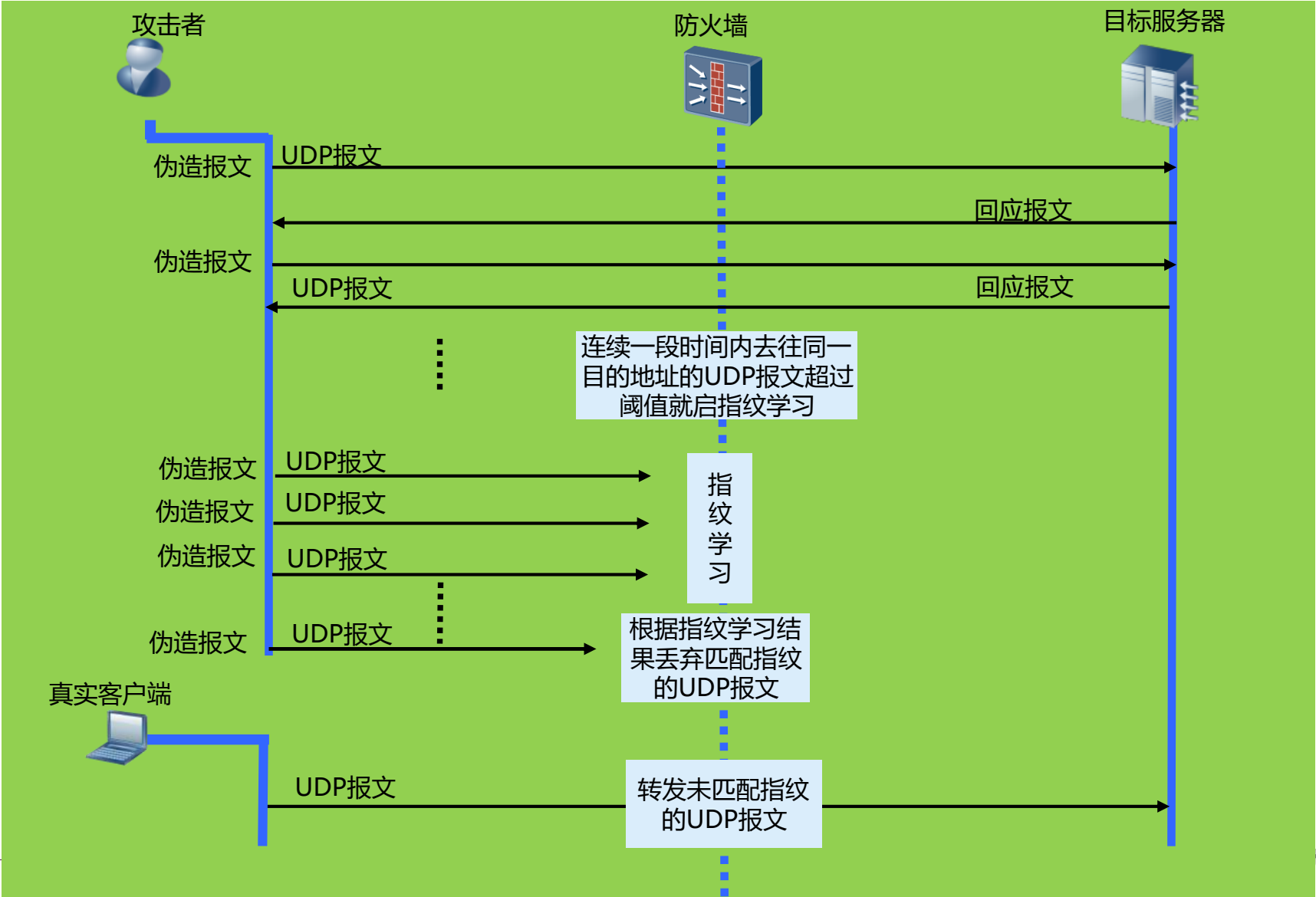
- **基于目的安全区域的限流**

- 以某个安全区域作为统计对象，对到达该安全区域的UDP流量进行统计并限流，超出流量将被丢弃。

- **基于会话的限流**

- 对每条UDP会话上的报文速率进行统计，如果会话上的UDP报文速率达到告警阈值，该条会话被锁定，后续命中该条会话的UDP报文都被丢弃。

UDP Flood攻击防范-指纹学习



UDP Flood攻击防范配置

- 防范配置

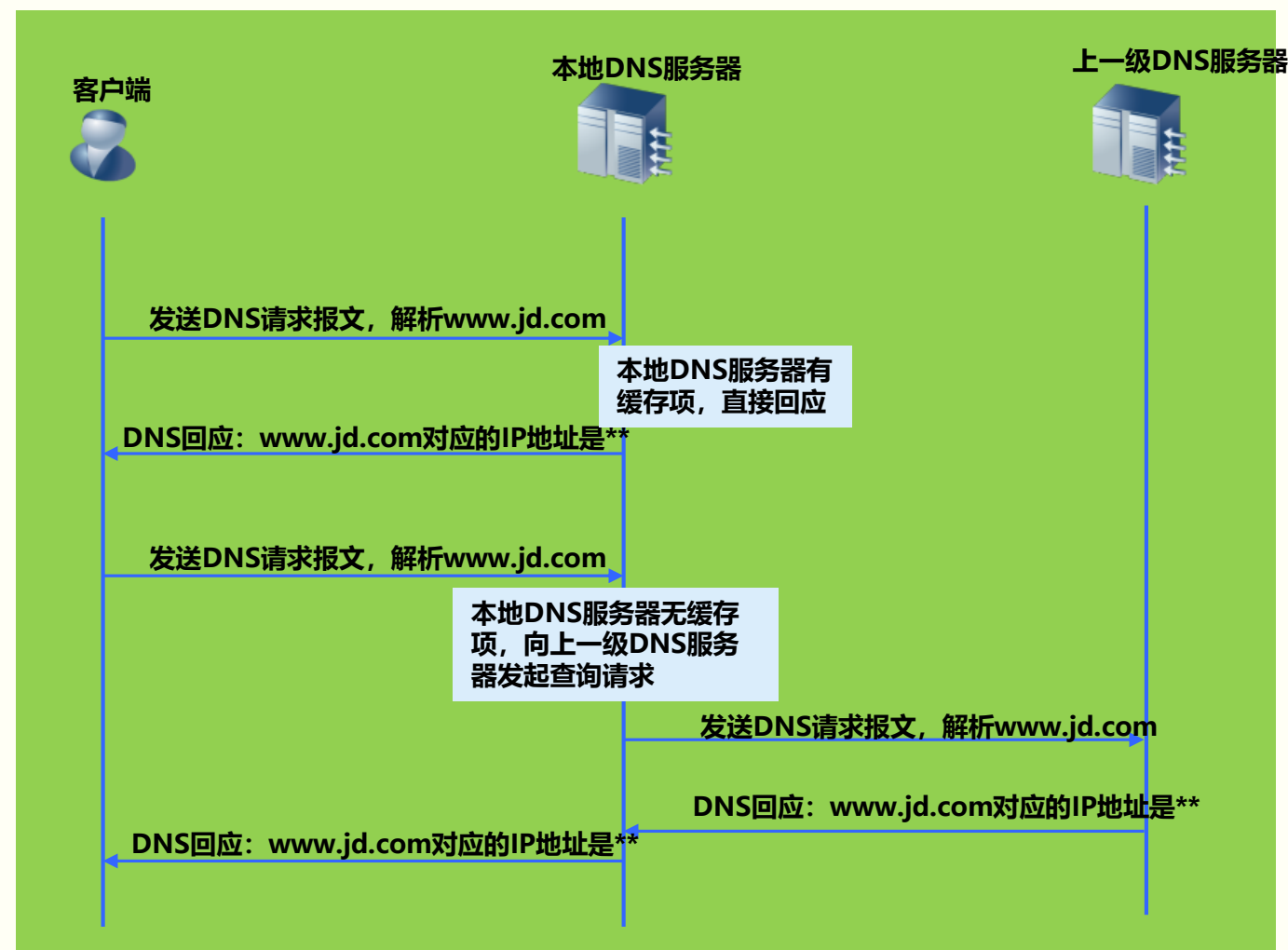
Udp/Icmp Flood攻击配置步骤:

- [USG] firewall defend udp-flood zone trust max-rate 3000
- [USG] firewall defend icmp-flood ip 202.169.1.100 max-rate 500
- [USG] firewall defend udp-flood interface GigabitEthernet 1/0/0 max-rate 1000

DNS Flood攻击防范

● 攻击介绍

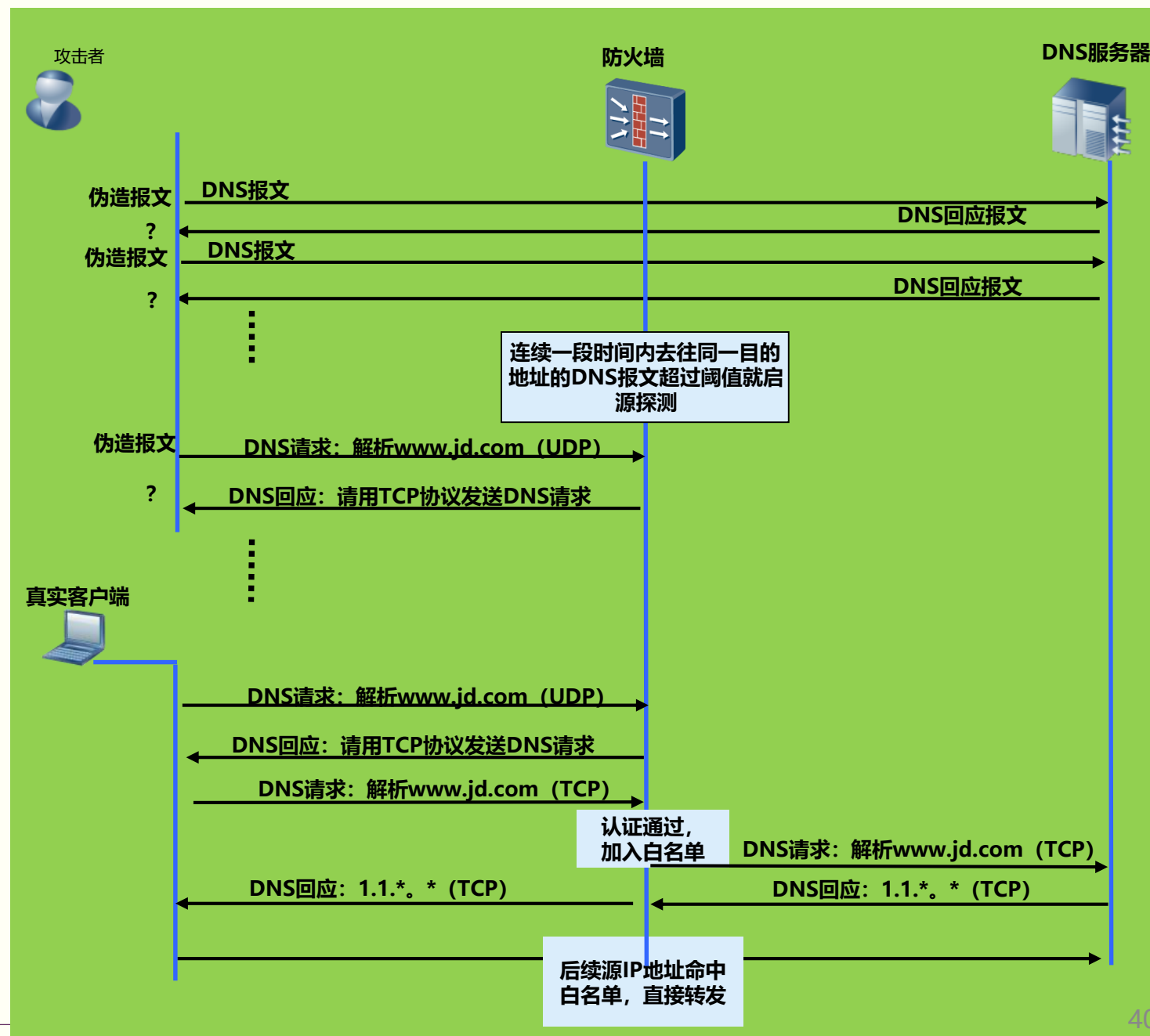
- 攻击者在短时间内通过向DNS（Domain Name System）服务器发送大量的查询报文，使得服务器不得不对所有的查询请求进行回应，导致DNS服务器无法为合法用户提供服务。



DNS Flood攻击防范

● 防范处理（源探测）

- 根据DNS报文查询速率进行DNS Flood攻击检测。当DNS查询报文速率超过告警设定值后，进行反弹反向探测源主机并结合白名单处理，对于超过了最大设定值DNS报文将直接丢弃。

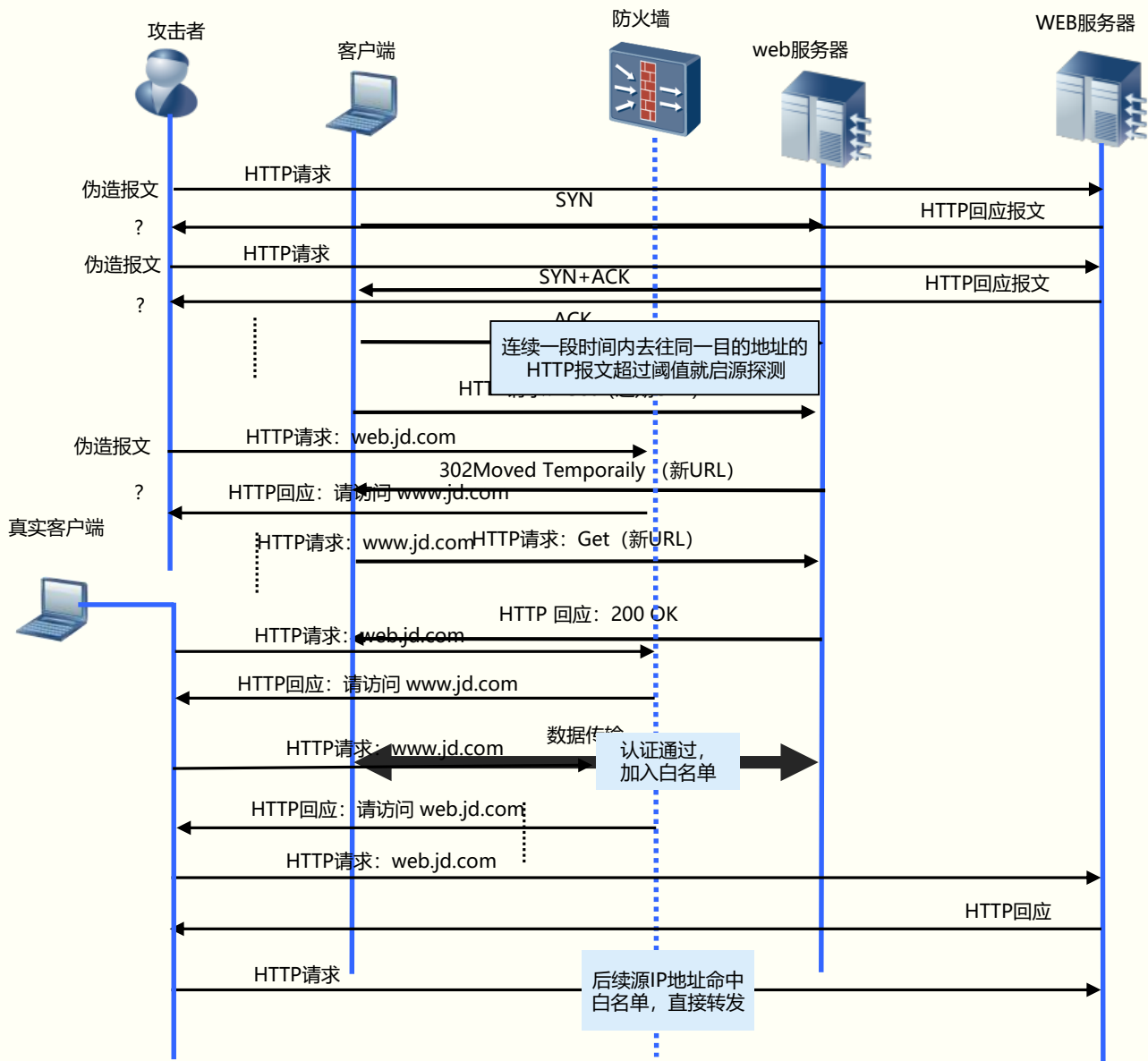


DNS Flood攻击防范配置

● 防范配置

- 执行命令firewall defend dns-flood enable, 启用DNS Flood攻击防范功能。
- 配置DNS Flood攻击防范参数。
 - firewall defend dns-flood interface Gigabit Ethernet 1/0/0 max-rate 100
 - firewall defend dns-flood ip ip-address 200.18.219.81max-rat 100
 - firewall defend dns-flood zone untrust max-rate 100
 - firewall defend dns-flood source-max-rate 10 interval 30

HTTP Flood攻击防范



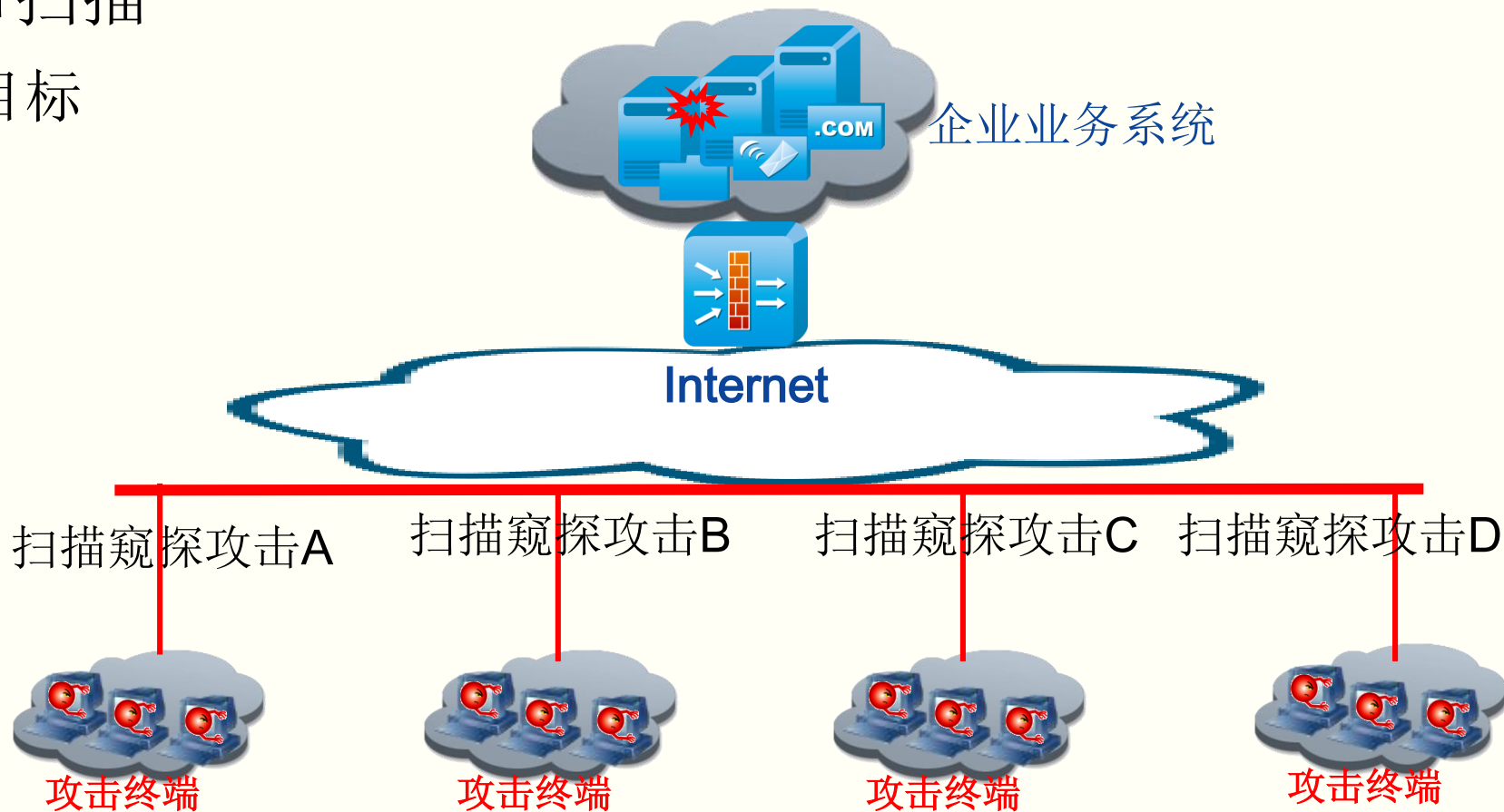
HTTP Flood攻击防范配置

- 防范配置

- 执行命令firewall defend http-flood enable, 启用HTTP Flood攻击防范功能。
- 配置HTTP Flood攻击防范参数。
 - firewall defend http-flood interface Gigabit Ethernet 1/0/0 max-rate 100
 - firewall defend http-flood interface Gigabit Ethernet 1/0/0 alter-rate 100

IP地址扫描与端口扫描

- 识别潜在攻击目标
- 识别目标弱点



地址扫描攻击防范

● 攻击介绍

- 运用ping程序探测目标地址，以用来确定目标系统是否存活的标识。也可使用TCP/UDP报文对目标系统发起探测（如TCP ping）。

● 处理方法

- 检测进入防火墙的ICMP、TCP和UDP报文，由该报文的源IP地址获取统计表项的索引，如目的IP地址与前一报文的IP地址不同，则将表项中的总报文个数增1。如在一定时间内报文的个数达到设置的阈值，记录日志，并根据配置决定是否将源IP地址自动加入黑名单。

● 攻防配置

```
[USG] firewall zone untrust
[USG-zone-untrust] statistic enable ip outzone
[USG] firewall defend ip-sweep max-rate 1000
[USG] firewall defend ip-sweep blacklist-timeout 5
[USG] firewall defend ip-sweep enable
```

端口扫描攻击防范

● 攻击介绍

- Port Scan攻击通常使用一些软件，向大范围的主机的一系列TCP/UDP端口发起连接，根据应答报文判断主机是否使用这些端口提供服务。

● 处理方法

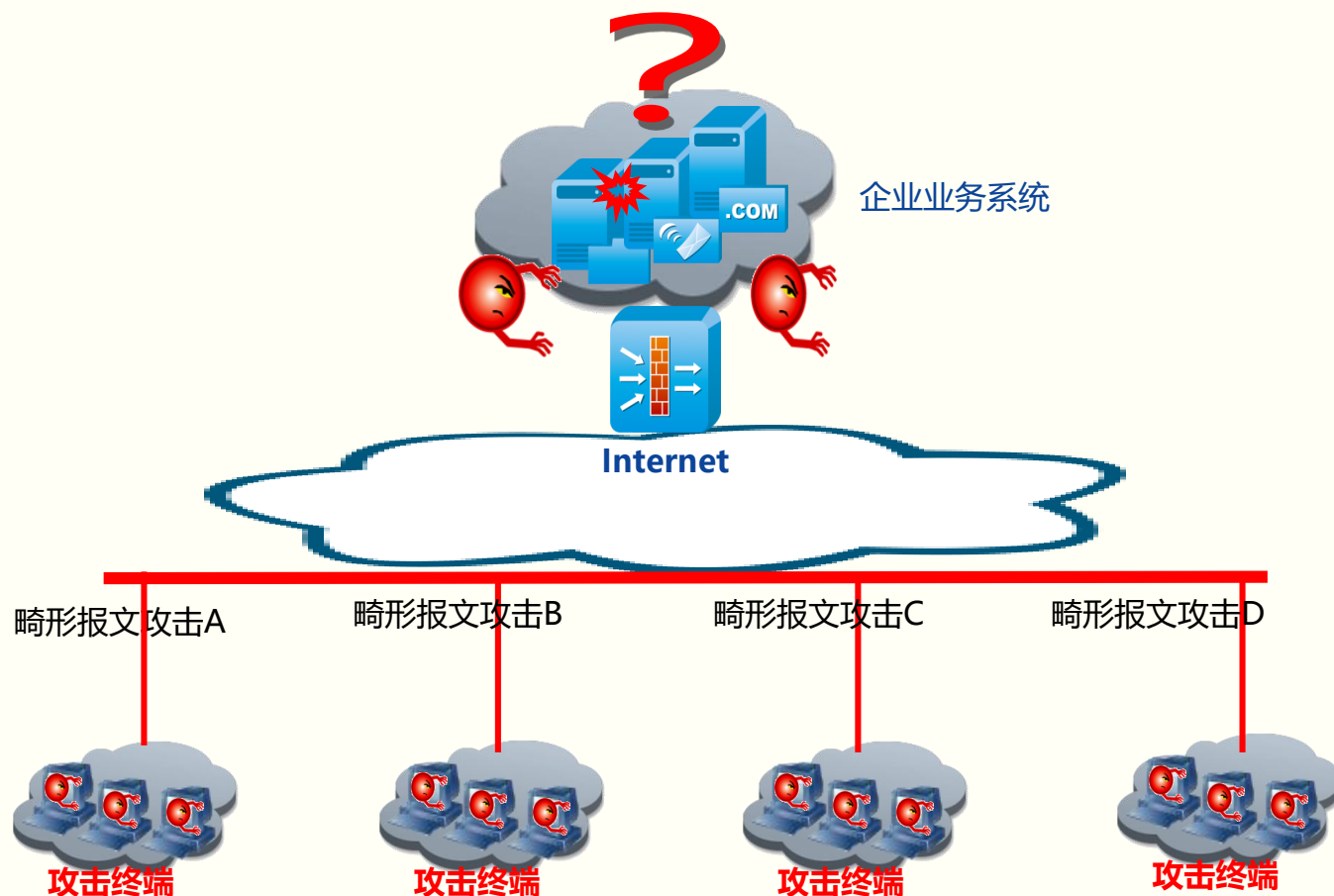
- 检测进入防火墙的TCP报文或UDP报文，由该报文的源IP地址获取统计表项的索引，如目的端口与前一报文不同，将表项中的报文个数增1。如果报文的个数超过设置的阈值，记录日志，并根据配置决定是否将源IP地址加入黑名单。

● 攻防配置

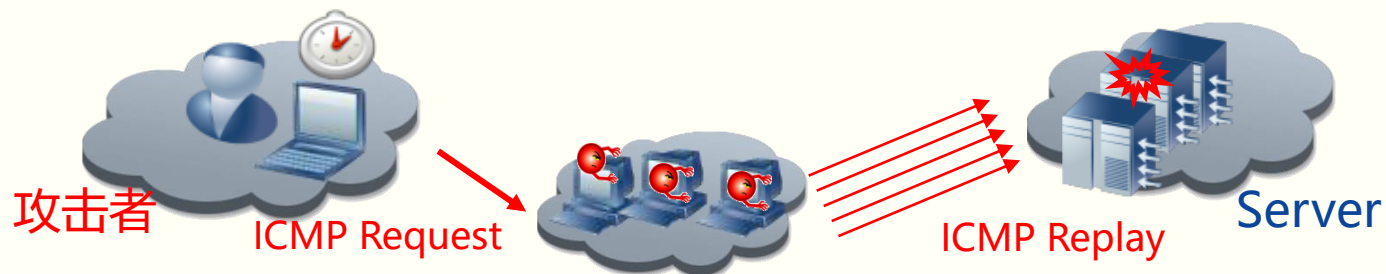
```
[USG] firewall zone untrust
[USG-zone-untrust] statistic enable ip outzone
[USG] firewall defend port-scan max-rate 1000
[USG] firewall defend port-scan blacklist-timeout 5
[USG] firewall defend port-scan enable
```

畸形报文攻击

- 畸形报文：
 - 有缺陷的IP报文
- 攻击手段：
 - 黑客通过向目标服务器发送大量含有缺陷的IP报文，
- 导致结果：
 - 使目标主机或服务器在处理这类报文时崩溃。



SMURF攻击防范



● 攻击介绍

- Smurf攻击方法是发ICMP请求，该请求包的目标地址设置为受害网络的广播地址，这样该网络的所有主机都对此ICMP应答请求作出答复，导致网络阻塞。

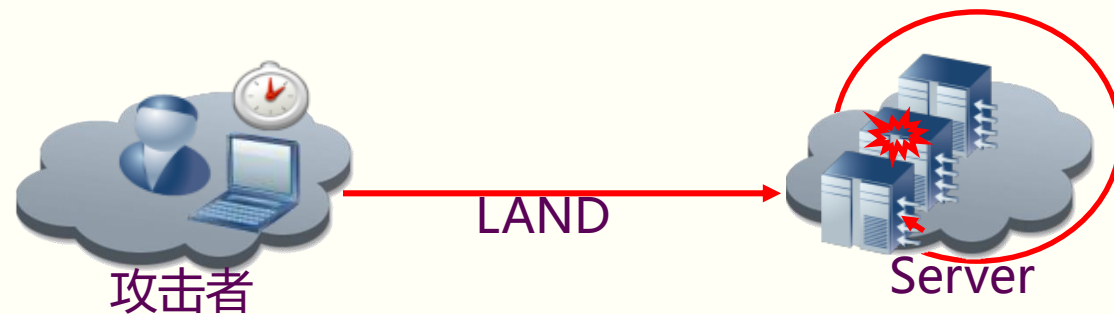
● 处理方法

- 检查ICMP应答请求包的地址是否为子网广播地址或子网的网络地址，如是，则直接拒绝，并将攻击记录到日志。

● 攻防配置

- firewall defend smurf enable

LAND攻击防范



● 攻击介绍

- 把TCP 的源地址和目标地址都设置成某一个受害者的IP地址。这将导致受害者向它自己的地址发送SYN-ACK消息，结果这个地址又发回ACK消息并创建一个空连接，占用系统资源或使目的主机崩溃。

● 处理方法

- 对每一个的IP报文进行检测，若其源地址与目的地址相同，或者源地址为环回地址(127.0.0.1)，则直接拒绝，并将攻击记录到日志。

● 攻防配置

- firewall defend land enable

Fraggle攻击防范

- **攻击介绍**

- Fraggle类似于Smurf攻击，使用UDP应答消息而非ICMP。UDP端口7(ECHO)和端口19(Chargen)在收到UDP报文后，大量无用的应答报文，占满网络带宽。

- **处理方法**

- 检查进入防火墙的UDP报文，若目的端口号为7或19，则直接拒绝，并将攻击记录到日志，否则允许通过。

- **攻防配置**

- firewall defend fraggle enable

IP Fragment攻击

● 攻击介绍

- IP报文中有几个字段与分片有关：DF位、MF位，Fragment Offset、Length。如果上述字段的值出现矛盾，而设备处理不当，会对设备造成一定的影响，甚至瘫痪。

● 处理方法

- 检查IP报文中与分片有关的字段（DF位、MF位、片偏置量、总长度）是否以下矛盾，如发现含有如下矛盾，则直接丢弃。将攻击记录到日志：
 - DF位为1，而MF位也为1或Fragment Offset不为0；
 - DF位为0，而Fragment Offset + Length > 65535。

● 攻防配置

- [USG]firewall defend ip-fragment enable

IP spoofing攻击防范

- **攻击介绍**

- 为了获得访问权，或隐藏入侵者的身份信息，入侵者生成带有伪造源地址的报文。

- **处理方法**

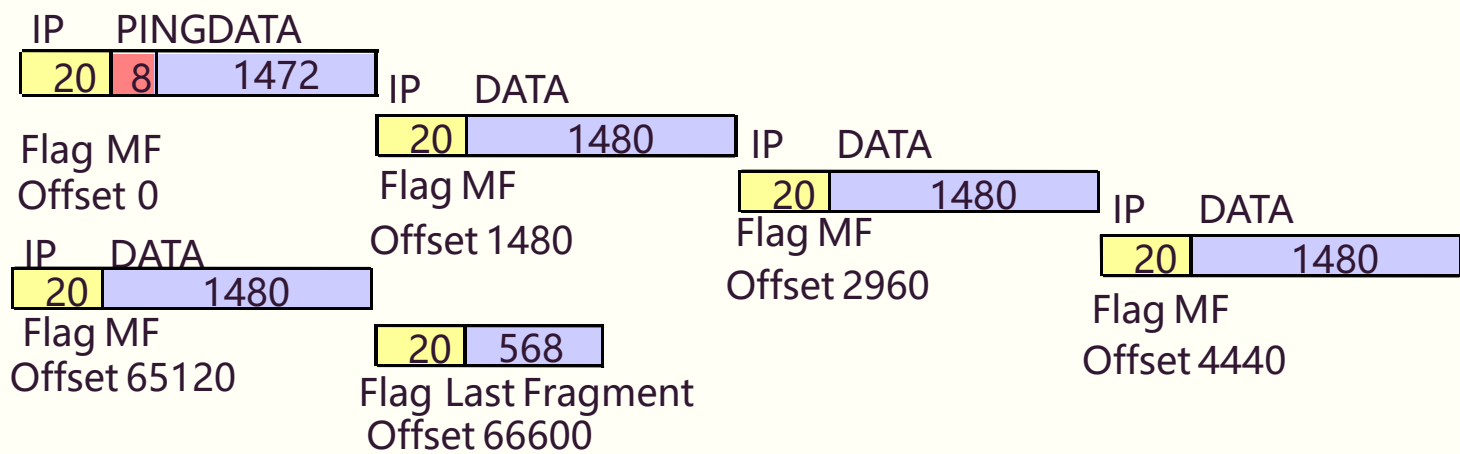
- 检测每个接口流入的IP报文的源地址与目的地址，并对报文的源地址反查路由表，入接口与以该IP地址为目的地址的最佳出接口不相同的IP报文被视为IP Spoofing攻击，将被拒绝，并进行日志记录。

- **攻防配置**

- firewall defend ip-spoofing enable

Ping of Death攻击

- 攻击介绍
 - IP报文的长度字段为16位，这表明一个IP报文的最大长度为65535。Ping of Death，就是利用一些尺寸超大的ICMP报文对系统进行的一种攻击。
- 处理方法
 - 检测ICMP请求报文长度是否超过65535KB，若超过丢弃报文并记录日志。
- 攻防配置
 - [USG] firewall defend ping-of-death enable



TCP Flag攻击

• 攻击介绍

- TCP报文包含6个标志位：URG、ACK、PSH、RST、SYN、FIN，不同的系统对这些标志位组合的应答是不同的，可用于操作系统探测。

• 处理方法

- 处理方法：检查TCP报文的各个标志位，若出现
 - 6个标志位全为1或6个标志位全为0；
 - SYN和FIN位同时为1；syn和rst同时为1；fin和urg同时为1；rst和fin同时为1；
 - 直接丢弃满足以上任一条件的报文，并记录日志。

• 攻防配置

- [USG]firewall defend tcp-flag enable

Tear Drop攻击

- 攻击介绍
 - Teardrop攻击利用在TCP/IP堆栈中信任IP碎片报文头所包含的信息来实现攻击。IP报文通过MF位、Offset字段、Length字段指示该分段所包含是原包哪一段信息，某些TCP/IP在收到含有重叠偏移伪造分段时将崩溃。
- 处理方法
 - 缓存分片信息，每一个源地址、目的地址、分片ID相同的为一组，最大支持缓存10000组分片信息。在分片缓存的组数达到最大时，如果后续分片报文要求建立新组，则直接丢弃。
- 攻防配置
 - [USG]firewall defend teardrop enable

	IP	PING	DATA						
TEAR	20	8	1472						
	Flag MF		IP	DATA					
	Offset 0		20	remainder					
				Flag Last Fragment					
				Offset 500					
	IP	PING	DATA						
NORMAL	20	8	1472						
	Flag MF			IP	DATA				
	Offset 0			20	remainder				
					Flag Last Fragment				
					Offset 1480				

WinNuke攻击防范

● 攻击介绍

- WinNuke攻击通常向装有Windows系统的特定目标的NetBIOS端口（139）发送OOB（out-of-band）数据包，引起一个NetBIOS片断重叠，致使已与其他主机建立连接的目标主机崩溃。还有一种是IGMP分片报文，一般情况下，IGMP报文是不会分片的，所以，不少系统对IGMP分片报文的处理有问题。

● 处理方法

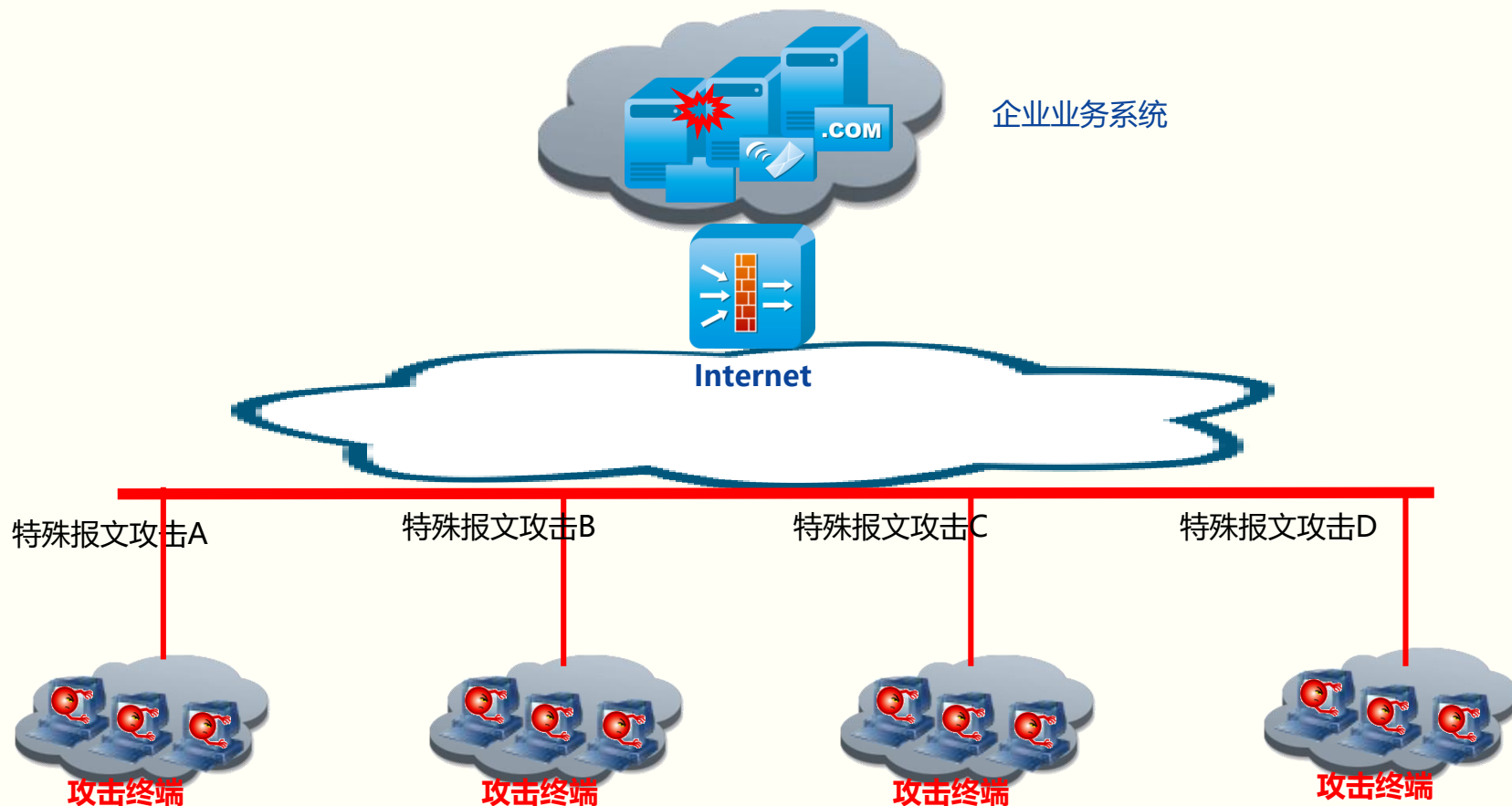
- WinNuke攻击1 检测数据包目的端口是否为139，并且检查TCP-URG位是否被设置；
- WinNuke攻击2 检测进入的IGMP报文是否为分片报文，如是分片报文，则直接丢弃。

● 攻防配置

- firewall defend winnuke enable

特殊报文攻击

- 攻击特点：
 - 一种潜在的攻击行为
 - 不具直接的破坏行为
- 攻击结果
 - 探测网络结构
 - 为后续发送真正的攻击做准备



超大ICMP报文攻击防范

- **攻击介绍**

- 超大ICMP报文攻击是指利用长度超大的ICMP报文对目标系统进行攻击。对于有些系统，在接收到超大ICMP报文后，由于处理不当，会造成系统崩溃、死机或重启。

- **处理方法**

- 用户可以根据实际网络需要配置允许通过的ICMP报文的最大长度，当实际ICMP报文的长度超过该值时，防火墙认为发生了超大ICMP报文攻击，将丢弃该报文。

- **攻防配置**

- firewall defend large-icmp enable
- firewall defend large-icmp max-length [length]

ICMP不可达报文攻击防范

- **攻击介绍**

- 不同的系统对ICMP不可达报文的处理方式不同，有的系统在收到网络或主机不可达的ICMP报文后，对于后续发往此目的地址的报文直接认为不可达，从而切断了目的地与主机的连接。攻击者利用这一点，伪造不可达ICMP报文，切断受害者与目的地的连接，造成攻击。

- **处理方法**

- 启动ICMP不可达报文攻击防范功能，防火墙对ICMP不可达报文进行丢弃并记录攻击日志。

- **攻防配置**

- firewall defend icmp-unreachable enable

Tracert报文攻击防范

● 攻击介绍

- Tracert报文攻击是攻击者利用TTL为0时返回的ICMP超时报文，和达到目的地址时返回的ICMP端口不可达报文来发现报文到达目的地所经过的路径，它可以窥探网络的结构。

● 处理方法

- 配置Tracert报文攻击防范就是对于检测到的超时的ICMP报文或UDP报文，或者目的端口不可达报文，给予丢弃。

● 攻防配置

- firewall defend tracert enable

本章小结

- 了解当前网络空间安全面临的威胁
- 树立正确的网络安全观
- 掌握基于防火墙的常见的网络攻击与防御措施